AREM · UNIVERSIDAD DE LA SABANA · MÓDULO 07

Normatividad y cumplimiento

Cómo una obligación legal se convierte en una decisión de arquitectura

Objetivo: identificar la normativa que aplica al sistema de un cliente colombiano y traducirla en controles concretos, ubicados sobre componentes concretos.

Profesor: Ing. César Augusto Vega Fernández

01 · OBJETIVO

Qué se lleva del módulo

El cumplimiento como decisión de diseño, no como anexo legal

01 **Determinar**

Establecer qué normativa aplica realmente al sistema del cliente, y cuál no.

02 **Traducir**

Convertir cada obligación legal en un control técnico ubicado en un componente.

03 **Evaluar**

Recorrer el sistema con un checklist y separar lo que cumple de lo que no.

04 **Proponer**

Recomendar los cambios de arquitectura que cierran cada brecha encontrada.

ENTREGABLE · TALLER 6

- Inventario de datos personales del sistema, con su categoría
- Normativa aplicable, con la razón de por qué aplica
- Checklist evaluado componente por componente sobre el diagrama C4
- Brechas encontradas y el cambio de arquitectura que cada una exige

Por qué esto es un tema de arquitectura

El abogado dice qué hay que cumplir; el arquitecto decide dónde se implementa

LA OBLIGACIÓN LEGAL

«El responsable debe garantizar que la información sea veraz, completa y actualizada, y conservar prueba de la autorización del titular.»

se traduce en

LA DECISIÓN DE ARQUITECTURA

- Una tabla de autorizaciones con marca de tiempo y versión del aviso aceptado.
- Un mecanismo de actualización que propague el cambio a los sistemas que copiaron el dato.
- Registro inmutable de quién modificó qué y cuándo.

Sanción económica

La autoridad de protección de datos puede imponer multas de varios miles de salarios mínimos, además de ordenar el cierre temporal de operaciones de tratamiento.

Bloqueo del negocio

Sin cumplimiento no hay contrato con el Estado ni con clientes corporativos que exijan certificación.

Costo de reparar tarde

Agregar trazabilidad a un sistema que no la tiene obliga a rediseñar el acceso a datos. Es el mismo costo exponencial del riesgo arquitectónico.

Nadie incumple a propósito. Se incumple porque el requisito nunca se tradujo a un componente, y en la auditoría no hay dónde señalarlo.

Qué normativa aplica y a quién

Primero se determina el alcance; después se evalúa

Ley 1581 de 2012 Régimen general de protección de datos personales	A toda organización que trate datos personales en Colombia. Es el punto de partida siempre.
Decreto 1074 de 2015 Reglamentación (compila el Decreto 1377 de 2013)	Detalla el consentimiento, los deberes del responsable y el encargado, y el registro de bases de datos.
Ley 1266 de 2008 Habeas data financiero y crediticio	Solo si el sistema administra información financiera, crediticia o comercial de personas.
Ley 1712 de 2014 Transparencia y acceso a la información pública	Solo a entidades públicas y a quienes administran recursos o funciones públicas. Aplica a GobData.

NORMAS SECTORIALES

Salud: historia clínica y su interoperabilidad.
Financiero: circulares de la Superintendencia Financiera.
Estado: política de Gobierno Digital y marco de arquitectura pública.

OBLIGACIÓN QUE SE OLVIDA

Registrar las bases de datos ante la autoridad de protección de datos. No es opcional y se verifica en auditoría.

La normativa cambia. Verifiquen siempre contra la fuente oficial antes de citarla en el entregable.

Los ocho principios de la Ley 1581

Cada uno con la decisión de arquitectura que le corresponde

	PRINCIPIO	QUÉ EXIGE	CÓMO SE IMPLEMENTA
1	**Legalidad**	El tratamiento se sujeta a la ley	Ninguna: es la condición de todo lo demás
2	**Finalidad**	El dato se usa solo para el fin informado	Etiquetar cada dato con su finalidad y bloquear usos distintos
3	**Libertad**	Se requiere consentimiento previo e informado	Tabla de autorizaciones con versión del aviso y marca de tiempo
4	**Veracidad**	El dato debe ser exacto y estar actualizado	Mecanismo de rectificación que propague el cambio aguas abajo
5	**Transparencia**	El titular puede saber qué datos suyos existen	Endpoint de consulta de datos propios, no un correo a un buzón
6	**Acceso restringido**	Solo accede quien tiene relación con la finalidad	Autorización por registro, no solo por pantalla o por rol
7	**Seguridad**	Protección contra pérdida, acceso o uso no autorizado	Cifrado, segmentación y los controles del Módulo 6
8	**Confidencialidad**	Obligación de reserva, incluso después del vínculo	Cláusulas con encargados y revocación de accesos al desvincular

Son ocho, no seis. Los dos que más se omiten son finalidad —el que más consecuencias de diseño tiene— y seguridad, que es todo el Módulo 6.

No todos los datos personales son iguales

La categoría determina el control, y algunos tienen tratamiento prohibido por defecto

Dato público	Consta en registros públicos o documentos oficiales sin reserva.	Control estándar de integridad y disponibilidad.
Dato semiprivado	Interesa al titular y a un sector determinado, como el historial crediticio.	Acceso restringido y trazabilidad de consultas.
Dato privado	Solo es relevante para el titular: dirección, teléfono, correo personal.	Autorización expresa y cifrado en tránsito y reposo.
Dato sensible	Afecta la intimidad o su uso indebido puede generar discriminación: salud, biometría, origen étnico, convicciones, vida sexual, afiliación sindical.	Tratamiento prohibido salvo excepciones legales. Autorización explícita, y el titular no está obligado a autorizar.

MENORES DE EDAD

Los datos de niñas, niños y adolescentes tienen protección reforzada: el tratamiento está restringido y debe respetar su interés superior. En sistemas educativos esto es la regla, no la excepción.

TRANSFERENCIA AL EXTERIOR

Enviar datos a un país sin nivel adecuado de protección está restringido. Alojar en la nube fuera del país es una transferencia y debe justificarse.

Ejercicio de dos minutos: ¿qué categoría tiene cada dato del ERD de su cliente? La respuesta define la mitad de los controles.

Quién responde por qué

La cadena de responsabilidad se refleja en la arquitectura

Titular

La persona natural cuyos datos se tratan.

Derechos: conocer, actualizar, rectificar, suprimir y revocar la autorización.

El sistema debe tener una forma de ejercerlos, no un correo de contacto.

Responsable

Quien decide sobre la finalidad y el contenido del tratamiento.

Es el garante principal del cumplimiento ante la autoridad.

En el proyecto: la organización cliente.

Encargado

Quien trata los datos por cuenta del responsable.

Sigue instrucciones y no puede usar los datos para fines propios.

En la arquitectura: cada proveedor de nube, de correo o de analítica.

Precisión importante: el «oficial de protección de datos» es una figura del reglamento europeo. La norma colombiana exige designar una persona o área responsable de atender consultas y reclamos de los titulares, que no es exactamente lo mismo. Cítenlo con precisión en el entregable.

Cuándo aplica cada estándar internacional

Ninguno aplica por defecto: cada uno tiene su disparador

ISO/IEC 27001 Sistema de gestión de seguridad de la información	Cuando el cliente necesita certificarse, o cuando un contrato se lo exige. Aporta estructura aunque no se certifique.	**Aplicable a casi cualquier cliente**
GDPR Reglamento europeo de protección de datos	Solo si se tratan datos de personas que están en la Unión Europea. No aplica por tener un sitio web accesible desde allá.	**Rara vez aplica a un cliente local**
PCI-DSS Seguridad de datos de la industria de tarjetas de pago	Solo si el sistema almacena, procesa o transmite datos de tarjeta. Delegar el cobro en una pasarela reduce drásticamente el alcance.	**Aplica solo si se tocan datos de tarjeta**
NIST SP 800-53 Catálogo de controles de seguridad y privacidad	Es obligatorio para sistemas federales de Estados Unidos. Fuera de ahí es una referencia de buenas prácticas, no una exigencia.	**Referencia, no obligación**

Error frecuente en el taller: auditar una clínica colombiana contra NIST SP 800-53. Se ve exhaustivo y no significa nada.

Cómo se hace una evaluación de cumplimiento

Cuatro pasos, sobre el diagrama que ya existe

PASO 1

Inventariar los datos

Liste qué datos personales maneja el sistema y clasifique cada uno. El ERD del Módulo 3 es el punto de partida.

PASO 2

Determinar el alcance

Establezca qué normativa aplica y por qué. Descarte explícitamente la que no aplica: eso también es un hallazgo.

PASO 3

Ubicar cada obligación

Recorra el diagrama de contenedores y señale en qué componente vive el control de cada obligación. Si no vive en ninguno, es una brecha.

PASO 4

Documentar la brecha

Por cada incumplimiento: qué falta, qué componente hay que cambiar y qué prioridad tiene.

El paso 3 es el que distingue este curso de uno de derecho informático: una obligación que no se puede señalar sobre un componente del diagrama todavía no está implementada, por más que aparezca en la política de privacidad.

Dónde vive cada obligación

Checklist aplicado componente por componente sobre GobData

OBLIGACIÓN	COMPONENTE	CONTROL QUE LA IMPLEMENTA	ESTADO
Consentimiento informado	Portal de trámites	Registro de autorización con versión del aviso, canal y marca de tiempo	Cumple
Finalidad declarada	API y base de datos	Etiqueta de finalidad por campo; bloqueo de usos no declarados	Brecha
Acceso y circulación restringida	API de aplicación	Autorización por registro según la relación del funcionario con el trámite	Parcial
Trazabilidad y auditoría	Almacén de bitácora	Registro inmutable de acceso, modificación y supresión, separado de la base operativa	Brecha
Derechos del titular	Portal de trámites	Función de consulta, rectificación y supresión de datos propios	Brecha
Retención y supresión	Base de datos y respaldos	Política de retención aplicada también a las copias de seguridad	Brecha
Seguridad del dato	Toda la arquitectura	Cifrado, segmentación de red y los controles del Módulo 6	Parcial
Contrato con encargados	Proveedores externos	Cláusulas de tratamiento con cada proveedor que toca datos personales	Cumple

Cinco brechas sobre ocho obligaciones. Ninguna se resuelve con un documento: las cinco exigen cambiar la arquitectura.

Cuando el sistema incorpora inteligencia artificial

Tres obligaciones que aparecen y que suelen pasarse por alto

Transferencia internacional

Enviar datos a un proveedor de IA alojado fuera del país es una transferencia internacional, aunque sea una llamada a una API.

QUÉ HACER

Verificar dónde se procesa, qué se retiene y por cuánto tiempo. Documentarlo en el registro de tratamiento.

Finalidad del entrenamiento

Usar datos recogidos para prestar un servicio con el fin de entrenar un modelo es una finalidad distinta a la informada.

QUÉ HACER

Requiere autorización específica, o trabajar con datos anonimizados de forma efectiva y no solo con el nombre borrado.

Aislamiento por rol en las respuestas

Un asistente que consulta documentos internos puede revelarle a un usuario información que su rol no le permite ver.

QUÉ HACER

El control de acceso debe aplicarse a los documentos que alimentan la respuesta, no solo a la pantalla.

La pregunta de auditoría para cualquier función de IA: ¿qué datos personales salieron del sistema, hacia dónde, con qué autorización y por cuánto tiempo se quedan allá?

Privacidad desde el diseño

Cuatro decisiones que salen baratas al diseñar y caras al reparar

Minimizar los datos

Recoger solo lo necesario para la finalidad declarada.

El dato que no se recoge no se puede filtrar, ni hay que protegerlo, ni justificarlo en auditoría.

Clasificar y etiquetar

Asignar categoría de sensibilidad a cada tipo de dato desde el modelo de información.

Permite aplicar controles proporcionales en vez de tratar todo igual.

Consentimiento trazable

Registrar cuándo, cómo y para qué se obtuvo la autorización.

Sin el registro, el consentimiento existe pero no se puede probar, que ante la autoridad es lo mismo que no tenerlo.

Reducir el alcance regulatorio

Delegar en terceros especializados el manejo de los datos más regulados.

Usar una pasarela de pagos saca del sistema los datos de tarjeta y con ellos buena parte de la carga de cumplimiento.

La cuarta es la menos obvia y la más estratégica: el mejor control sobre un dato regulado es no tenerlo.

Dónde verificar y con qué trabajar

Siempre la fuente oficial antes que el resumen de un blog

Superintendencia de Industria y Comercio

AUTORIDAD DE PROTECCIÓN DE DATOS

Texto de la ley, guías, registro de bases de datos y decisiones sancionatorias que sirven como jurisprudencia práctica.

MinTIC

POLÍTICA DE GOBIERNO DIGITAL

Guías de protección de datos y lineamientos de arquitectura para entidades públicas. Aplica directamente a GobData.

ISO/IEC 27001

ESTRUCTURA DE CONTROLES

Aunque el cliente no se certifique, el anexo de controles sirve como checklist ordenado de seguridad de la información.

Matriz de cumplimiento

HOJA DE CÁLCULO DEL EQUIPO

Una fila por obligación, con componente, control, estado y evidencia. Es el entregable del Taller 6.

Regla de citación del entregable: cada obligación debe citar la norma y el artículo. «Según la ley de datos» no es una cita y no se acepta.

13 · ACTIVIDAD

Evaluación de cumplimiento en clase · 40 minutos

En equipos, sobre el sistema del cliente real

10 min

Inventariar y clasificar

Listen los datos personales del sistema del cliente a partir de su ERD y asignen categoría a cada uno. Marquen los sensibles.

8 min

Determinar el alcance

Decidan qué normativa aplica y por qué. Escriban también qué descartan y con qué razón.

15 min

Ubicar cada obligación

Recorran el diagrama de contenedores señalando dónde vive el control de cada obligación. Lo que no tenga componente es una brecha.

7 min

Priorizar las brechas

Ordenen las brechas por riesgo y digan qué cambio de arquitectura exige cada una.

ERRORES QUE VAMOS A BUSCAR

- Normativa listada sin decir por qué aplica
- Obligaciones que no se pueden señalar sobre un componente
- Datos sensibles tratados como datos comunes
- Brechas sin propuesta de cambio de arquitectura

Al terminar: el resultado es la matriz de cumplimiento del Taller 6, y alimenta la sustentación del segundo corte.

PARA LLEVARSE

Cumplimiento en cuatro ideas

01 **Primero el alcance**

Determinar qué aplica y qué no es parte del trabajo, y descartar también es un hallazgo.

02 **Ocho principios, no seis**

Finalidad y seguridad son los que más consecuencias de diseño tienen y los que más se omiten.

03 **Toda obligación vive en un componente**

Si no se puede señalar sobre el diagrama, todavía no está implementada.

04 **El mejor control es no tener el dato**

Minimizar y delegar reduce la carga regulatoria por diseño, no por documento.

Próximo paso: Taller 6 · matriz de cumplimiento del sistema del cliente, con brechas priorizadas.

LECTURAS RECOMENDADAS

Ley 1581 de 2012 y Decreto 1074 de 2015

Superintendencia de Industria y Comercio — guías y RNBD

Ley 1712 de 2014 — transparencia y acceso a información pública

MinTIC — Política de Gobierno Digital

ISO/IEC 27001 — anexo de controles